

New Survey of 250+ Organizations Uncovers Key Cybersecurity & Compliance Trends for 2026 ✕

[Register](#) →

ISO 27001 Controls Explained: A Guide to Annex A

ISO-27001 > ISO 27001 Controls Explained: A Guide to Annex A

If you're preparing to get ISO 27001 certified — or [recertified](#) — one of the biggest hurdles is making sure your controls are effective. That's because your information security management system (ISMS) must meet both the [requirements of Clauses 4-10](#) and the security controls defined in Annex A.

To help you establish or improve your ISMS and [prepare for an audit](#), we'll take a closer look at the ISO 27001:2022 controls below: what they are, what's new, and how to approach them.

What are ISO 27001 Annex A controls?

Information security controls are the specific processes and policies you put in place to mitigate risks. Annex A of ISO/IEC 27001:2022 outlines 93 controls grouped into four

This website utilizes technologies such as cookies to enable essential site functionality, as well as for analytics, personalisation, and



4 domains in the 2013 version) to help you use.

entary resource. It goes into more detail for each control's purpose, how it works, and best



The Ultimate Guide to ISO 27001

If you're looking to build a compliant ISMS and achieve certification, this guide has all the details you need to get started.

[Get the guide](#)

How many controls are there in ISO 27001?

ISO 27001:2022 Annex A includes 93 controls, divided into four categories.

- Clause 5: Organizational Controls (37 controls)
- Clause 6: People Controls (8 controls)
- Clause 7: Physical Controls (14 controls)
- Clause 8: Technological Controls (34 controls)

When the International Organization for Standardization (ISO) updated the ISO 27001:2013 standard in 2022, they added 11 new controls:

This website utilizes technologies such as cookies to enable essential site functionality, as well as for analytics, personalisation, and marketing services. [Privacy Policy](#)

- A.8.16: Monitoring activities
- A.8.23: Web filtering
- A.8.28: Secure coding

What this means for you: If you certified under ISO/IEC 27001:2013, you'll need to map your old controls to the new 2022 structure, document how you're handling the new requirements, and update your Statement of Applicability (SoA).

How Annex A works with Clauses 4–10

Annex A isn't standalone. While Clauses 4–10 define the management system requirements (context, leadership, planning, support, operations, performance evaluation, improvement), Annex A provides the specific security controls you can select to manage risks.

In other words, Clauses 4-10 are the "what" and Annex A is the "how".

How you satisfy the ISO 27001 clauses and Annex A controls will depend on your organization. The ISO 27001 standard is written so that different types of organizations can meet the legal, regulatory, and contractual requirements in their own way.

Clauses 4-10 and your ISO 27001 risk assessment are your roadmap. Use them to decide which Annex A controls apply to your organization, and explain exclusions in your [Statement of Applicability](#). For example, if none of your employees work remotely, you may exclude A.6.7 — but you'll need to justify that decision to your auditor.

Recommended reading

This website utilizes technologies such as cookies to enable essential site functionality, as well as for analytics, personalisation, and



ISO 27001:2022 and ISO 27002:2022: What Were The Updates & How to Comply

[Read More](#) >

What are the 4 themes of ISO 27001?

Think of the four themes as broad pillars of information security: organizational, people, physical, and technological. Topics like: how do you approach company security? How do you handle asset management? How do you address physical security and cybersecurity?

This website utilizes technologies such as cookies to enable essential site functionality, as well as for analytics, personalisation, and

d to reduce risk in that area. Below, we'll walk
ame and what auditors will expect.

Physical controls

[Menu](#)

Does your organization have a clear set of policies about keeping its ISMS secure? Are information security roles and responsibilities clearly defined and effectively communicated? Are proper access controls in place?

Organizational controls prove that security isn't an afterthought, but a central part of your governance and operations. The controls encompass:

Information security policies

The strength of your information security policies directly influences every other category.

Auditors will be looking for:

- High-level documentation of information security policies
- A regular process to review and update those policies
- A clear explanation for how those policies work with the other needs of the business

Organization of information security

It's all well and good for the CISO to put security policies in place, but that's not sufficient for ISO 27001. Specifically defined security roles at every level of the organization are a must.

In each department, there should be zero ambiguity about information security responsibilities. There should also be plans for how any remote workers or vendors fit into the environment.

It's far easier for a single infosec professional to implement policies in a smaller office. However, you should still have a plan for organizing data security as your company grows.

Supplier relationships

Most companies are dependent on outside partnerships to some degree. When seeking ISO 27001 certification, businesses often focus on internal operations and operational systems and can easily overlook supply chain and [third-party risk management](#).

This website utilizes technologies such as cookies to enable essential site functionality, as well as for analytics, personalisation, and

se you can't control how someone else operates. all third-party vendors to a rigorous standard and an for third-party risk. You should also refuse to standards.

should not be able to view information that isn't

Access control encompasses who receives authentication information — like login credentials — and what privileges that information comes with. The more people with user access to corporate information, the more risk is introduced.

These controls address how to keep employee user IDs and passwords secure and limit non-essential access to applications through a formal access management process. They should be supported by documented procedures and user responsibilities.

Asset management

Any information asset is a potential security risk — if it's valuable to you, it's probably valuable to somebody else.

[ISO 27001 certification](#) requires your business to identify its information assets, classify them, and apply management processes based on those classifications.

For the controls in this domain, you should know:

- What is acceptable use of an information asset?
- Who is authorized to receive and share each asset?
- How to track an asset's location
- How to dispose of the asset, if necessary

Controls also cover how to safely store assets on removable media, such as USB drives.

Communications security

These controls cover information transfer, including how you exchange information, how you protect it when using electronic messaging like email, and how you use non-disclosure agreements.

Incident response

This website utilizes technologies such as cookies to enable essential site functionality, as well as for analytics, personalisation, and

reat, regardless of how prepared you might be. respond to security events and incidents.

irst? Who has the power to make decisions? What ave a documented [incident response plan](#) for urity incidents?

spects of business it

When business is significantly disrupted, information security can fall by the wayside.

Does your company have a plan to protect sensitive data during a serious operational upheaval?

Disruption can be anything from a natural disaster to a ransomware attack or political upheaval in the business's home country. It can also be internal, like an acquisition or change in company leadership.

Redundancy measures — including maintaining an inventory of spare parts and duplicate hardware and software— can help maintain business continuity and smooth operations during times of disruption.

Compliance

The final section details how your organization complies with information security laws.

Under laws like the EU's [General Data Protection Regulation \(GDPR\)](#), businesses can face heavy fines for infosec failures. ISO 27001 auditors want to see that you have a plan for mitigating compliance risk.

A 6.1-6.8: People controls

Human error is one of the biggest risk factors. People controls help you build a security-first culture by defining how your employees and contractors interact with data and information systems. They include practices like employee background checks and security awareness training.

Human resources security

The controls in this section require every employee to be clearly aware of their information security responsibilities.

This website utilizes technologies such as cookies to enable essential site functionality, as well as for analytics, personalisation, and

hired? This includes screening and background checks before employment.

Information security be communicated to employees? Security awareness education and training, the working, and non-disclosure agreements.

How do you ensure that employees do not compromise your information security after leaving?

A 7.1-7.13: Physical controls

How will you protect physical information assets? Even the strongest firewalls won't protect you if someone can walk into your server room unchecked.

Physical controls cover the protection of tangible assets and facilities, and include clear desk policies, storage and disposal protocols, and entry and access systems.

Physical and environmental security

Your organization should be protecting any physical location where it stores sensitive data. That means offices, data centers, customer-facing premises, and anywhere else that could compromise your information security if breached.

Security is more than just locks and guards. It demands that you think about access rights, asking questions like, "How do you determine who can enter a secure area like a server room?"

This theme also includes controls for ensuring employees implement physical safeguards. Someone leaving their laptop or mobile device behind in a cafe can be even worse than getting hacked. Remote as well as in-office workers should adopt a clear desk and clear screen policy so information cannot be accessed, seen, or taken by an unauthorized person.

Other controls in this series cover the risk of natural disasters. If your data center is damaged by a flood or earthquake, how will you ensure it remains protected against forced entry? If you can't ensure that, what else will you do to protect your sensitive data?

A 8.1-8.34: Technological controls

Most modern breaches exploit technology gaps. Technological controls define how you manage IT systems and infrastructure to ensure you're covering both prevention and resilience.

This website utilizes technologies such as cookies to enable essential site functionality, as well as for analytics, personalisation, and

who can access source code and how to locks.

arsenal, but ISO 27001 considers it important

olicy for managing encryption, with evidence that
tion for your business needs.

Make sure to pay special attention to how you manage cryptographic keys throughout their entire lifecycle, including a plan for what to do if a key becomes compromised.

Operations security

ISO 27001 requires your company to secure the information processing facilities and systems that [make up its ISMS](#).

These technological controls cover documentation of ISMS operating procedures, including change management and review procedures. Other subdomains cover malware protection, data backups, penetration testing, technical vulnerability management, and more.

If your company is tech-heavy, you'll also need to prove that your development and testing environments are secure.

Network security

Information is especially vulnerable while it's on the move. ISO 27001 broadly defines communication as any transit of information from one node of your network to another.

These controls prevent attackers from accessing sensitive information by exploiting flaws and vulnerabilities in your network security.

System acquisition, development, and maintenance

This control set is interested in how your ISMS evolves over time.

Whenever you introduce a new information security system or make changes to one you already use, information security should be at the forefront of your mind.

To meet these control requirements, you'll need to hold any new system to specific security requirements, rejecting any changes that don't meet your specifications.

This website utilizes technologies such as cookies to enable essential site functionality, as well as for analytics, personalisation, and

;



5 Steps to a Successful ISO 27001 Audit + Checklist

[Read More](#) >

Who is responsible for implementing ISO 27001 controls?

There's a common misconception that IT should be solely responsible for implementing the ISO 27001 controls that are applicable to an organization. In reality, Annex A spans multiple domains: Security, Privacy, Compliance, and more.

This website utilizes technologies such as cookies to enable essential site functionality, as well as for analytics, personalisation, and marketing.

The responsibility of multiple stakeholders and how those individuals are exactly will depend on the size, structure, and culture of the organization.

Ownership for each control early. During audits, clarity is key to avoid any difference.

ISO 27001 controls

At first glance, Annex A may seem overwhelming. But once you map controls to your risk assessment, the framework becomes much more manageable.

ISO 27001 doesn't expect you to implement every control. It expects you to choose the ones that address your risks, justify exclusions, and continually improve your ISMS. The better you understand your information security risk landscape, the easier it will be to figure out which controls apply to you.

That said, we don't blame you if the [ISO 27001 certification process](#) still feels daunting.

That's why we built Secureframe.

Our compliance automation platform makes it easier and faster to get ISO 27001 certified. With powerful automation and a team of ISO 27001 experts, we'll help you build a compliant ISMS, monitor controls, manage vendor risk, complete a gap analysis, and get you 100% audit-ready fast.

FAQs

How many ISO controls are there?

ISO 27001:2022 Annex A includes 93 controls, divided into four categories. The previous version, ISO 27001:2013 Annex A included 114 controls, divided into 14 categories.

What are the objectives of ISO 27001 controls?

All ISO 27001 controls have an objective to help organizations implement, maintain, and continuously improve an information security management system that meets the requirements of ISO 27001. For example, the objective of control A.5.1 Information security policy is to provide management direction and support for information security in accordance with business requirements and relevant laws and regulations.

This website utilizes technologies such as cookies to enable essential site functionality, as well as for analytics, personalisation, and

What's new there in ISO 27001:2022?

2. It's important to note that the overall number of controls decreased from 114 to 93 in ISO 27001:2022. However, none of the controls were simply merged into 24 controls, 1 control was removed, and the remaining 58 controls are mostly unchanged.

The Core Requirements of Clauses 4-10

ISO 27001 vs ISO 27002: What's the Difference?

Tweet

Share

Share

 Send

ISO 27001 Overview

- > What is ISO 27001 Certification?
- > Why is ISO 27001 Important? Benefits of Compliance
- > The History of ISO 27001
- > ISO 27001 vs SOC 2: Which Framework is Right for You?
- > ISO 27001 vs NIST CSF: What's the Difference & How to Choose

ISO 27001 Requirements

- > An Introduction to the ISO 27001 ISMS
- > The Core Requirements of Clauses 4-10
- > ISO 27001 Controls Explained: A Guide to Annex A

This website utilizes technologies such as cookies to enable essential site functionality, as well as for analytics, personalisation, and

Difference?

5

: A Step-by-Step Guide

tion Take?

- › [ISO 27001 Certification Validity](#)

How to Prepare for an ISO 27001 Audit

- › [ISO 27001 Documentation: What's Required for Compliance?](#)
- › [ISO 27001 Evidence Collection List for Your Certification Audit](#)
- › [How to Do an ISO 27001 Risk Assessment](#)
- › [How to Conduct an ISO 27001 Internal Audit](#)

Automating ISO 27001 Compliance

- › [Manual vs. Automated: Streamline Your ISO 27001 Compliance](#)
- › [The Cost Benefits of ISO 27001 Compliance Automation](#)
- › [Why ISO 27001 Compliance Automation Unveils Better Security Insights](#)
- › [Maintaining ISO 27001 Compliance](#)

ISO 27001 Resources and Tools

- › [ISO 27001 Compliance Checklists](#)
- › [ISO 27001 Policy Templates](#)
- › [Trusted ISO 27001 Audit Firms](#)
- › [ISO 27001 Penetration Testing Firms](#)

This website utilizes technologies such as cookies to enable essential site functionality, as well as for analytics, personalisation, and

[Products](#)

[Secureframe Comply](#)

[Secureframe Trust](#)

[Why Secureframe?](#)

Product Updates

Pricing

Solutions

Small Business
Enterprise

Frameworks

SOC 2
ISO 27001
HIPAA
PCI DSS
CCPA
GDPR
View All

Partners

Trusted Partners
Auditors
Service Providers
Become A Partner
Explore Partners

Company

About
Careers [We're Hiring](#)
Newsroom
Customers
Trust Center

Resources

Blog
Compliance Hubs
Compliance Resources
Guides
Glossary
Knowledge Base Extension
API Reference

Support

Help
Contact Us
Schedule A Demo
Status [99.99%](#)
Support Metrics
Your Privacy Choices 

This website utilizes technologies such as cookies to enable essential site functionality, as well as for analytics, personalisation, and